HAICHAIN

HAICHAIN CRYPTOGRAPHIC DEFENSE & PROTOCOL RISK ASSESSMENT

INSTITUTIONAL RISK DUE DILIGENCE REPORT V1.1 • CRYPTOGRAPHIC DEFENSE STANDARD

HAICHAIN: Institutional Risk Due Diligence Report

Mathematical Proofs, Threat Modeling & Red-Team Verification Matrix for Tier-1 Allocators and Audit Firms

TARGET AUDIENCE	CRYPTOGRAPHIC SECURITY	PROTOCOL KERNEL
Tier-1 Venture Allocators & Audit Firms	Hardware Passkey • 9 Invariants Bound	HAICHAIN v1.1 • CapLeaf 223 Bytes

HAICHAIN INSTITUTIONAL RISK DUE DILIGENCE REPORT

Mathematical Proofs, Threat Modeling & Red-Team Verification Matrix

Target Audience: Tier-1 Venture Capitalists (a16z crypto, Paradigm, Sequoia), Institutional Custodians, and Top-Tier Audit Firms (OtterSec, Neodyme, Kudelski Security)
Protocol Version: HAICHAIN Kernel v1.1 / CapLeaf v1 (223 Bytes Wire Schema)
Standard: Anchor Framework (Solana L1) + Sui Move (`AgentCap`) + Tron Rail Intent Solver

1. EXECUTIVE SUMMARY & SECURITY PARADIGM

Autonomous AI agents executing financial micro-transactions introduce fundamentally distinct attack surfaces from human-operated DeFi: 1. **Zero Human-in-the-Loop Latency:** An AI agent executing tool calls can be coerced via Indirect Prompt Injection into issuing thousands of unauthorized payment vouchers in seconds. 2. **Key Exfiltration Vulnerability:** Running agent instances on distributed worker nodes (Cloudflare Workers, local desktop MCPs, serverless functions) increases the risk of private key exfiltration. 3. **Sybil Counterparty Proliferation:** In an open M2M network, malicious merchants can register unlimited burner domains to bypass domain-based rate limits.

To solve this without sacrificing sub-millisecond execution, **HAICHAIN decouples execution from custody**: - **Master Authority:** WebAuthn FIDO2 Biometric Hardware Passkey (P-256) retaining 100% sovereign ownership over the spending pot. - **Sub-Agent Authority:** Ephemeral Ed25519 keypairs strictly sandboxed inside out-of-process Policy Engines with zero access to underlying wallet seeds. - **On-Chain Merkle Anchor:** 223-byte leaf wire schema enforcing 9 non-malleable mathematical invariants (I_1 ... I_9).

2. FORMAL THREAT MODEL & LOSS BOUND FORMULAS

2.1. Attack Surface Taxonomy

Threat Class	Scenario	Conventional Web3 Exposure	HAICHAIN Worst-Case Ceiling
T_1 **(Indirect Prompt Injection)**	LLM coerced to pay unapproved merchant	Entire wallet drained ($100,000+$)	**E_{\text{theft}} = 0$** (Blocked by Merkle root whitelist)
T_2 **(Merchant Collusion)**	Legitimate merchant attempts double-claiming	Double-charge on user account	$E_{\textbf{theft}} = 0$ (Anchor monotonically enforces $P_i \le \min(C_i, R_i)$)
T_3 **(Probation Domain Flood)**	Sub-agent attempts loop drainage on new API	Cumulative exhaustion of pot	$E_{\textbf{theft}} \le M_{\textbf{tpl}}$ (Burned from parent template ceiling)
T_4 **(Complete Agent Compromise)**	Private key exfiltrated + colluding merchant	Total pot drained immediately	$E_{\textbf{theft}}(\tau) \le \min(B, K, W_p \cdot n(\tau, \omega_p))$

2.2. Theorem 6.1: Upper Bound on Worst-Case Theft (T_4)

Let τ be the total protocol response latency from the instant an unauthorized transaction is initiated to the instant the on-chain panic freeze transaction lands:

$$\tau = t_{detect} + t_{owner} + t_{land}$$

where: - $t_{detect} \leq 5.0s$ (telemetry anomaly detection threshold) - $t_{owner} \leq 2.0s$ (Passkey one-touch biometric authorization) - $t_{land} \leq 5.0s$ (Solana high-priority transaction inclusion)

Under full compromise of the agent's Ed25519 signing key and active collusion with an authenticated merchant in the active Merkle tree, the maximum cumulative theft $E_{theft}(\tau)$ is bounded by:

$$E_{theft}(\tau) \leq \min(B, \quad K, \quad W_p \cdot n(\tau, \omega_p), \quad \sum_{i:\, m_i \in <i>Ai>} E_i(\tau))$$

Where: - B: Total available pot balance (`pot.balance`). - K: Active leaf cumulative spend ceiling (`leaf.max_spend`). - W_p: Velocity limit per sliding window (`leaf.window_cap`). - ω_p: Window duration (typically $3{,}600s$). - $n(\tau, \omega_p) = \lceil \tau / \omega_p \rceil$: Number of sliding windows spanned during response window τ. For $\tau = 12s \ll 3600s$, $n(\tau, \omega_p) = 1$. - $\sum E_i$: Sum of escrow capacities locked across active channels for colluding merchants.

Corollary: For an institutional pot with $10{,}000$ USDT balance, a leaf budget cap of 50 USDT, and a velocity cap of 10 USDT / hour, an attacker compromising the agent's key cannot drain more than 10 **USDT** before the freeze takes effect, preserving $9{,}990$ **USDT (99.9%)** of capital.

---

3. RED-TEAM PENETRATION & HARDENING MATRIX

During the internal red-team forensic audit, 5 critical attack vectors were evaluated and hardened into the protocol kernel:

	Attack Vector	Vulnerability Mechanism	Hardened On-Chain Invariant
1	**Jito MEV Panic Front-Run**	Malicious voucher bundles placed ahead of owner Panic Freeze	**Panic Epoch Tag (I_6)** Channel tagged with epoch; instantly invalidated
2	**Window Straddle Double-Dip**	Splitting reserve across window boundary to draw 2× velocity	**Atomic Epoch Consumption** Reserve strictly burns window capacity in anchor
3	**Merchant Liquidity Hostage**	Uncooperative merchant leaves unspent channel un-settled	**OwnerForceReclaim (I_1)** Zero-claim channels unlocked immediately by master owner
4	**Rent Lamport Vampire Drain**	Third-party rent-recipient draining rent on channel close	**Canonical Rent Recipient** Rent strictly refunded to original funder (`grant_pot`)
5	**Indirect Micro-Loop Sybil**	1,000 child probation leaves draining small micro-reserves	**Template Budget Burn** `activate_child` burns parent `max_reserve` ceiling

4. MATHEMATICAL INVARIANTS AUDIT REPORT ($I_1 \dots I_9$)

Every on-chain instruction in `programs/haichain-core/src/lib.rs` preserves all 9 state invariants without exception:

1. I_1 (Conservation of Capital):

$$\text{Vault}_{ATA} + \sum_{\text{channels}} \text{Escrow}_j + \sum \text{Paid}_j + \text{Refunds} = \text{Net Deposits}$$

Verified by `test_invariant_i1_conservation` in test suite.

2. I_2 (Canonical Payee Safety):

$$\texttt{payee_ata} \equiv \texttt{get_associated_token_address}(\text{merchant}, \text{mint})$$

Enforced on-chain via Anchor constraint; prevents third-party token account redirection.

3. I_3 (Budget Ceiling):

$$\text{consumed} \le \texttt{max_spend} \quad \wedge \quad \texttt{budget_used} \le \texttt{budget_total}$$

Checked before every reserve or settlement execution.

4. I_4 (Autonomous Velocity Rate Limiter):

$$\texttt{window_used} \le \texttt{window_cap} \qquad \forall t \in [T_0, T_0 + \omega]$$

Prevents rapid automated capital drainage.

5. I_5 (Monotonic PDA Narrowing):

$$\text{Channel PDA} \subseteq \text{Grant PDA} \subseteq \text{Pot PDA}$$

Child instances cannot broaden permissions granted by parent.

6. I_6 (Panic Epoch & Freeze Isolation):

$$\texttt{pot.panic_epoch} == \texttt{channel.created_at_epoch} \quad \wedge \quad \neg \texttt{pot.frozen}$$

Instant protocol shutdown completely halts all voucher processing.

7. I_7 (Heartbeat Expiration):

$$\texttt{current_time} \le \texttt{valid_until}$$

Stale or abandoned sessions cannot execute new reserves.

8. I_8 **(Monotonic Settlement & Settle-Once):**

$$\text{paid}_{new} \leq \min(\texttt{cumulative_amount}, \texttt{reserved_amount}) \quad \wedge \quad \text{paid}_{new} \geq \text{paid}_{old}$$

Guarantees zero double-spending across channel vouchers.

9. I_9 **(Sybil Account Isolation):**

$$\texttt{PDA}(\text{"chan"}, \text{grant}, \texttt{channel_id}) \text{ is unique}$$

One capability leaf maps to exactly one on-chain account.

---

5. TOKENOMICS & REGULATORY COMPLIANCE

5.1. Zero-Dividend Pure Utility Standard (Howey & MiCA Immune)

- **Zero Passive Staking / Yield:** HAICHAIN has eliminated all forms of passive staking yield or dividends. The protocol offers no profit expectations derived from the entrepreneurial efforts of others.
- **50% Buyback & Burn:** 50% of protocol fees generated from network volume are used to purchase $HAISI on open DEX markets and burn it permanently, creating programmatic deflation directly tied to network utility.
- **50% Protocol Reserve Fund (CHGB):** 50% of protocol fees are directed into the autonomous slashable reserve fund to backstop provider SLAs and guarantee cross-chain liquidity.

5.2. Multi-Chain Settlement Capabilities

- **Solana L1 Anchor Kernel:** Native micro-voucher state machine with 223-byte leaf schema, running at 400ms finality.
- **Sui Move Linear Object Model (`AgentCap`):** Linear capability structs with zero `copy` or `drop` primitives, preventing duplicate delegation.
- **Tron TRC20 Rail Solver:** Off-chain intent verification with on-chain Merkle audit trail for low-cost USDT settlements in global emerging markets.

---

6. EXTERNAL AUDIT RECOMMENDATIONS & DATA ROOM ACCESS

The external audit package is organized into: - `/programs/haichain-core/src/lib.rs` (Anchor Rust Kernel v1.1) - `/programs/haichain-sui/sources/capleaf.move` (Sui Move Package) - `/sdk/typescript/src/capleaf.ts` (223-Byte LE Wire Schema & Merkle Tree) - `/sdk/typescript/src/policy-engine.ts` (Zero-Knowledge Key Isolation Sandbox) - `/tests/` (72 Passing Automated Fuzzing & Invariant Verification Tests)

Conclusion: HAICHAIN v1.1 provides the first mathematically proven, hardware-isolated payment layer for autonomous AI agents, setting the benchmark for institutional safety in the agentic economy.